



IDATA CHILE · DIAGNÓSTICO DE SEGURIDAD

Reporte de postura de seguridad

<https://www.duoc.cl>

56 / 100

F

Alcance

Prospección pasiva

Fecha del escaneo

2026-07-27 01:04 UTC

N° de informe

IDS-DEMO-DUOC

Hallazgos accionables

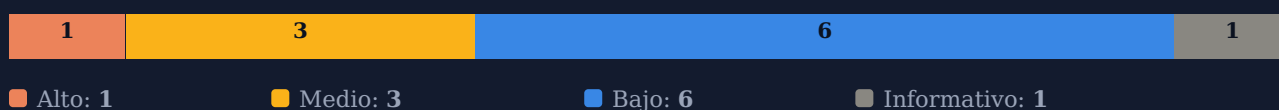
11

56

 / 100 · nota F

Cada hallazgo penaliza según su severidad multiplicada por la probabilidad de que se materialice. Los hallazgos informativos y los que no se pudieron evaluar no penalizan.

Distribución de hallazgos



Lo que exige atención primero

ALTO

Rastreadores activos sin mecanismo de consentimiento

Se tratan datos de los visitantes sin base de licitud desde el primer instante de la visita: es la infracción más fácil de constatar por la Agencia y la más visible para cualquier denunciante.

MEDIO

La CSP no restringe base-uri

Con una inyección de HTML el atacante puede insertar una etiqueta `<base>` y desviar todos los scripts de ruta relativa a su propio servidor, anulando la protección de los nonces. Es la evasión de CSP más habitual.

MEDIO

La CSP permite scripts sin restricción efectiva

Una política basada en listas de dominios se evade con archivos JSONP o librerías alojadas en esos mismos dominios: no detiene un XSS real.

MEDIO

Transferencia de datos a responsables fuera de Chile

Las transferencias internacionales requieren una garantía adecuada declarada. Sin ella, cada visita al sitio genera una transferencia no amparada.

BAJO

CSP presente pero laxa

La CSP no mitiga XSS de forma efectiva con estas directivas.

Semáforo por línea de servicio

Vulnerabilidades

86

4 hallazgo(s)

Activos

93

5 hallazgo(s)

Datos Personales

77

2 hallazgo(s)

Monitoreo

No evaluado

ALTO Datos Personales

Rastreadores activos sin mecanismo de consentimiento

Por qué importa: Se tratan datos de los visitantes sin base de licitud desde el primer instante de la visita; es la infracción más fácil de constatar por la Agencia y la más visible para cualquier denunciante.

Qué hacer: Implementar una CMP que bloquee los rastreadores hasta obtener consentimiento y registre la prueba de ese consentimiento.

MEDIO HTTP Headers

La CSP no restringe base-uri

Por qué importa: Con una inyección de HTML el atacante puede insertar una etiqueta `<base>` y desviar todos los scripts de ruta relativa a su propio servidor, anulando la protección de los nonces. Es la evasión de CSP más habitual.

Qué hacer: Añadir `"base-uri 'none'"` (o `'self'`) a la política.

MEDIO HTTP Headers

La CSP permite scripts sin restricción efectiva

Por qué importa: Una política basada en listas de dominios se evade con archivos JSONP o librerías alojadas en esos mismos dominios: no detiene un XSS real.

Qué hacer: Migrar a una CSP estricta con nonce por respuesta y `'strict-dynamic'`.

MEDIO Datos Personales

Transferencia de datos a responsables fuera de Chile

Por qué importa: Las transferencias internacionales requieren una garantía adecuada declarada. Sin ella, cada visita al sitio genera una transferencia no amparada.

Qué hacer: Declarar las transferencias en la política de privacidad y adoptar cláusulas contractuales u otro mecanismo de garantía adecuada.

BAJO HTTP Headers

CSP presente pero laxa

Por qué importa: La CSP no mitiga XSS de forma efectiva con estas directivas.

Qué hacer: Evitar `'unsafe-inline'/'unsafe-eval'` y comodines en `default-src`.

BAJO Exposición de información

Meta generator expone plataforma en /

Por qué importa: Facilita reconocimiento de tecnología/versión.

Qué hacer: Eliminar la meta tag generator en producción.

BAJO DNS y Correo

Falta registro SPF en www.duoc.cl

Por qué importa: Cualquiera puede enviar correo simulando ser este dominio: riesgo de fraude al cliente (phishing con la marca) y de daño reputacional.

Qué hacer: Publicar un TXT `'v=spf1 ... -all'` declarando los emisores autorizados.

BAJO DNS y Correo

Falta registro DMARC en www.duoc.cl

Por qué importa: Sin DMARC no hay política declarada ante correos falsificados ni visibilidad de quién está suplantando el dominio.

Qué hacer: Publicar `_dmarc.www.duoc.cl` TXT con `'v=DMARC1; p=quarantine; rua=mailto:...'`.

BAJO DNS y Correo

Sin registro CAA en www.duoc.cl

Por qué importa: Amplía la superficie para un certificado fraudulento emitido por una CA no prevista, habilitando sitios de phishing con HTTPS válido.

Qué hacer: Publicar CAA restringiendo la emisión a las CAs efectivamente usadas.

BAJO DNS y Correo

DNSSEC no habilitado en www.duoc.cl

Por qué importa: Las respuestas DNS del dominio no son verificables: un envenenamiento de caché puede desviar a los usuarios a infraestructura del atacante.

Qué hacer: Habilitar DNSSEC en el proveedor de DNS y publicar el registro DS en el registrar.

INFORMATIVO Exposición de activos

El descubrimiento de subdominios no pudo completarse

Por qué importa: Un inventario parcial da una falsa sensación de superficie reducida. Los activos no descubiertos son precisamente los que nadie vigila.

Qué hacer: Repetir el escaneo más tarde. Si el problema persiste, aportar el listado de subdominios conocidos para completar el inventario manualmente.

Mapa de superficie de ataque

05

1	1	1	1
activos inventariados	accesibles por web	sobre HTTPS	IP(s) distintas

Tabla de activos

ACTIVO	ORIGEN	IP(S)	ESTADO	TECNOLOGÍA	CDN / WAF
www.duoc.cl	target	136.248.244.61	HTTPS 200	WordPress	—

1

principio(s) con brecha

1

con observaciones

3

sin hallazgos

BRECHA Licitud del tratamiento

Todo tratamiento requiere una base de licitud. Cargar rastreadores antes del consentimiento trata datos sin fundamento desde la primera visita.

SEVERIDAD	HALLAZGO	ACCIÓN
ALTO	Rastreadores activos sin mecanismo de consentimiento	Implementar una CMP que bloquee los rastreadores hasta obtener consentimiento y registre la prueba de ese consentimiento.

SIN HALLAZGOS Información al titular

El titular debe conocer quién trata sus datos, con qué finalidad y cómo ejercer sus derechos, antes de entregarlos.

OBSERVACIÓN Finalidad y transferencias

Los datos solo pueden usarse para el fin declarado; las transferencias internacionales exigen una garantía adecuada declarada.

SEVERIDAD	HALLAZGO	ACCIÓN
MEDIO	Transferencia de datos a responsables fuera de Chile	Declarar las transferencias en la política de privacidad y adoptar cláusulas contractuales u otro mecanismo de garantía adecuada.

SIN HALLAZGOS Proporcionalidad y minimización

Solo deben recogerse los datos necesarios. Los datos sensibles exigen consentimiento explícito y justificación reforzada.

SIN HALLAZGOS Seguridad del tratamiento

Deben adoptarse medidas técnicas adecuadas para proteger los datos. Se evidencia en el transporte cifrado, la configuración TLS y las cookies.

Semáforo basado en señales técnicas observables al momento del escaneo. No constituye una calificación legal de cumplimiento ni sustituye la asesoría del servicio de Datos Personales de IDATA.

Detalle completo para el equipo técnico del cliente.

ID	CATEGORÍA	ESTADO	EVIDENCIA	REFERENCIAS
trackers_without_consent	Datos Personales	fail	Google Tag Manager: googletagmanager.com/gtm.js	Ley 21.719 — licitud del tratamiento
csp_missing_base_uri	HTTP Headers	fail	default-src 'self'; script-src 'self' 'unsafe-inline' 'unsafe-eval' https://*.issuu.com https://analytics.tiktok.com https://snap.licdn.com *.rovot.io *.google.com *.newrelic.com *.gstatic.com *.userw	OWASP CSP, CWE-79
csp_script_src_permissive	HTTP Headers	fail	default-src 'self'; script-src 'self' 'unsafe-inline' 'unsafe-eval' https://*.issuu.com https://analytics.tiktok.com https://snap.licdn.com *.rovot.io *.google.com *.newrelic.com *.gstatic.com *.userw	OWASP CSP
international_data_transfer	Datos Personales	warning	Google LLC (EE.UU.)	Ley 21.719 — transferencias internacionales
csp_unsafe	HTTP Headers	warning	default-src 'self'; script-src 'self' 'unsafe-inline' 'unsafe-eval' https://*.issuu.com https://analytics.tiktok.com https://snap.licdn.com *.rovot.io *.google.com *.newrelic.com *.gstatic.com *.userw	OWASP CSP
metadata_exposed_generator@/	Exposición de información	warning	<meta name="generator" content="WordPress 6.8.1	CWE-200
spf_missing@www.duoc.cl	DNS y Correo	fail	TXT observados: (ninguno)	RFC 7208
dmarc_missing@www.duoc.cl	DNS y Correo	fail		RFC 7489
caa_missing@www.duoc.cl	DNS y Correo	warning		RFC 8659
dnssec_missing@www.duoc.cl	DNS y Correo	warning		RFC 4033
asset_discovery_incomplete@www.duoc.cl	Exposición de activos	warning	crt.sh devolvió HTTP 404	CIS Control 1

Próximos pasos

08

Este diagnóstico es el punto de partida. IDATA Chile acompaña el cierre de las brechas identificadas con sus servicios de **Controles, Gobierno y Monitoreo continuo**, y mantiene la postura de seguridad medida en el tiempo en lugar de volver a fotografiarla una vez al año.

<https://idatachile.com>

Alcance y limitaciones

09

Este reporte se basa en información pública observada de forma pasiva, sin enviar payloads ni interactuar de forma intrusiva con los activos.

No constituye una garantía absoluta de seguridad: es una fotografía del estado observable al momento del escaneo (2026-07-27 01:04 UTC). Un resultado sin hallazgos no implica ausencia de vulnerabilidades, solo que no fueron observables por los métodos empleados.

Las recomendaciones están sujetas a validación técnica en el contexto de la infraestructura del cliente. Los hallazgos referidos a CVE son informativos: no se comprobó su explotabilidad y no debe asumirse que el activo sea vulnerable.

La evaluación de cumplimiento de la Ley 21.719 se limita a señales técnicas observables y no constituye una calificación legal ni sustituye la asesoría del servicio de Datos Personales de IDATA Chile.